

VULNERABILITY ASSESSMENT & PENETRATION TEST REPORT

Internal Lab Network Security Assessment

Client / Organization	Red
Engagement Type	Internal Network Penetration Test (Authorized Lab Environment)
Targets In Scope	192.168.15.21, 192.168.9.69
Engagement Dates	19–20 June 2026
Report Date	20 June 2026
Prepared By	N.M.I Raisul Bari
Document Classification	CONFIDENTIAL

This document contains confidential and proprietary information. Distribution is limited to authorized personnel of the engaging organization.

Table of Contents

Table of Contents	2
1. Executive Summary	4
2. Scope of Engagement	5
3. Methodology	6
4. Risk Rating Definitions	7
5. Summary of Findings	8
6. Attack Narrative	9
7. Detailed Findings — 192.168.15.21	10
A-01 — vsftpd 2.3.4 Backdoor (CVE-2011-2523)	10
A-02 — Pre-Installed Unauthenticated Root Bind Shell ("ingreslock")	11
A-03 — UnrealIRCd Backdoored Binary	12
A-04 — Java RMI Registry Insecure Default Configuration — Remote Code Execution	13
A-05 — SQL Injection in Custom Web Application (DVWA)	14
A-06 — Weak / Default Web Application Credentials	15
A-07 — Unauthenticated Trust-Based Remote Shell Services (rexec / rlogin / rsh)	16
A-08 — Excessive Database Account Privileges — Web Application Connects to MySQL as root	17
A-09 — Outdated Samba File Sharing Service	18
A-10 — Outdated / Historically Compromised ProFTPD Service	19
A-11 — Outdated VNC Server with Weak Authentication	20
A-12 — Unauthenticated Network File System (NFS) Export	21
A-13 — Legacy SSL/TLS Weaknesses on Database Service	22
A-14 — Apache Tomcat Manager Interface Exposed	23
A-15 — WebDAV Enabled on Production Web Server	24
A-16 — Additional Vulnerable Web Applications Exposed (phpMyAdmin, TWiki)	25
A-17 — Full Path Disclosure via SQL Injection	26
A-18 — Cleartext Telnet Service	27
A-19 — Outdated SSH Daemon Version	28
A-20 — Outdated DNS Server (BIND)	29
8. Detailed Findings — 192.168.9.69	30
B-01 — Unidentified Service on Port 514/tcp	30
B-02 — Third-Party Helpdesk Web Component Exposed	31
9. Positive Security Observations	32
10. Testing Limitations	33
11. Recommendations & Remediation Roadmap	34
11.1 Immediate (within 24–48 hours)	34
11.2 Short-Term (within 2 weeks)	34

11.3 Medium-Term (within 90 days)	34
12. Conclusion	35
Appendix A: Tools Used	36
Appendix B: Full Port / Service Inventory — 192.168.15.21.....	37
Appendix C: Full Port / Service Inventory — 192.168.9.69.....	38

This is a sample report based on the Metasploitable2

1. Executive Summary

Between 19 and 20 June 2026, an authorized internal network penetration test was conducted against two hosts within a designated lab environment: 192.168.15.21, a Linux server running a deliberately vulnerable training distribution (commonly distributed as “Metasploitable2”), and 192.168.9.69, a Windows-based host assessed at a lighter, reconnaissance-only depth. The objective was to identify, validate, and where safe to do so, exploit security weaknesses across network services and a hosted web application, and to report findings with actionable remediation guidance.

A total of 22 findings were identified across both hosts: 6 Critical, 6 High, 4 Medium, 4 Low, and 2 Informational. The assessment confirmed complete, unauthenticated remote-to-root compromise of 192.168.15.21 via three independent vectors (a trojaned FTP server, a pre-installed root bind shell, and a backdoored IRC daemon), in addition to full exploitation of a SQL injection vulnerability in a hosted web application that yielded complete extraction and cracking of application credentials. A further critical Java RMI remote-code-execution vulnerability was confirmed present, though live exploitation was not completed due to an attacker-side network routing limitation rather than any mitigating control on the target.

192.168.9.69 was found to be considerably better hardened: SMB signing was enabled and enforced, and no critical or high-severity issues were identified within the scope of testing performed. Two informational items are noted for inventory/verification purposes.

Overall, 192.168.15.21 should be considered fully compromised and unsuitable for any production use; it is consistent with a host intentionally built for security training rather than a hardened production asset. Remediation priorities are detailed in Section 12.

2. Scope of Engagement

Authorization: This assessment was conducted within a private, isolated lab network with explicit authorization to test the in-scope hosts using port scanning, vulnerability scanning, exploitation, and post-exploitation techniques. No production systems or third-party assets were in scope or were tested.

In-Scope Targets:

- 192.168.15.21 — Linux server (primary target; full assessment depth)
- 192.168.9.69 — Windows-based host (reconnaissance-depth assessment)

Out of Scope: Denial-of-service testing, physical security testing, social engineering, and any host not explicitly listed above.

This is a sample report based on the Metasploitable2

3. Methodology

Testing followed a standard black-box-to-grey-box network penetration testing methodology, broadly aligned with the phases of PTES (Penetration Testing Execution Standard):

- Reconnaissance & Port Scanning — Service and version discovery using Nmap (TCP connect/SYN scanning, service-version detection, default and vulnerability-category NSE script categories).
- Service Enumeration — Web content discovery (Gobuster), web vulnerability scanning (Nikto, attempted), and manual protocol-level verification (e.g. HTTP response inspection).
- Vulnerability Analysis — Correlation of identified service versions against known vulnerabilities, with manual verification of automated tool output to filter false positives.
- Exploitation — Manual and tool-assisted exploitation using sqlmap (SQL injection), Hydra (credential testing), Metasploit Framework (service exploitation), and netcat (direct backdoor verification).
- Post-Exploitation Analysis — Database privilege enumeration, credential extraction and offline cracking, and assessment of further pivot opportunities (including an attempted, unsuccessful OS-command-execution escalation via the database layer).

Tools Used: Nmap, Gobuster, Nikto, sqlmap, Hydra, Metasploit Framework (msfconsole), netcat, curl.

4. Risk Rating Definitions

Findings in this report are rated using qualitative severity levels aligned to CVSS v3.1 base score ranges where applicable. Findings arising from intentional design/configuration weaknesses or planted backdoors rather than a specific published CVE are rated qualitatively using the same scale.

Severity	CVSS Range	Definition
Critical	9.0 – 10.0	Trivially exploitable, typically unauthenticated, resulting in full system or data compromise.
High	7.0 – 8.9	Exploitable with limited prerequisites, resulting in significant compromise of confidentiality, integrity, or availability.
Medium	4.0 – 6.9	Exploitable under specific conditions, or resulting in limited compromise / information disclosure.
Low	0.1 – 3.9	Minimal direct impact; typically informational hardening or defense-in-depth gaps.
Informational	N/A	Observations not representing a direct vulnerability, included for completeness or inventory purposes.

This is a sample report based on the IV

5. Summary of Findings

The table below lists all findings identified during this engagement, ordered by severity. Full technical detail for each finding, including evidence and remediation guidance, is provided in Sections 7 and 8.

ID	Finding	Host	Severity	Status
A-01	vsftpd 2.3.4 Backdoor (CVE-2011-2523)	192.168.15.21	Critical	Exploited
A-02	Pre-Installed Unauthenticated Root Bind Shell ("ingreslock")	192.168.15.21	Critical	Exploited
A-03	UnrealIRCd Backdoored Binary	192.168.15.21	Critical	Confirmed
A-04	Java RMI Registry Insecure Default Configuration — Remote Code Execution	192.168.15.21	Critical	Confirmed
A-05	SQL Injection in Custom Web Application (DVWA)	192.168.15.21	Critical	Exploited
A-07	Unauthenticated Trust-Based Remote Shell Services (rexec / rlogin / rsh)	192.168.15.21	Critical	Identified
A-06	Weak / Default Web Application Credentials	192.168.15.21	High	Exploited
A-08	Excessive Database Account Privileges — Web Application Connects to MySQL as root	192.168.15.21	High	Confirmed
A-09	Outdated Samba File Sharing Service	192.168.15.21	High	Identified
A-10	Outdated / Historically Compromised ProFTPD Service	192.168.15.21	High	Identified
A-11	Outdated VNC Server with Weak Authentication	192.168.15.21	High	Identified
A-12	Unauthenticated Network File System (NFS) Export	192.168.15.21	High	Identified
A-13	Legacy SSL/TLS Weaknesses on Database Service	192.168.15.21	Medium	Confirmed
A-14	Apache Tomcat Manager Interface Exposed	192.168.15.21	Medium	Identified
A-15	WebDAV Enabled on Production Web Server	192.168.15.21	Medium	Identified
A-16	Additional Vulnerable Web Applications Exposed (phpMyAdmin, TWiki)	192.168.15.21	Medium	Identified
A-17	Full Path Disclosure via SQL Injection	192.168.15.21	Low	Confirmed
A-18	Cleartext Telnet Service	192.168.15.21	Low	Identified
A-19	Outdated SSH Daemon Version	192.168.15.21	Low	Identified
A-20	Outdated DNS Server (BIND)	192.168.15.21	Low	Identified
B-01	Unidentified Service on Port 514/tcp	192.168.9.69	Informational	Identified
B-02	Third-Party Helpdesk Web Component Exposed	192.168.9.69	Informational	Identified

6. Attack Narrative

This section summarizes the chronological flow of testing against the primary target, 192.168.15.21, for context ahead of the detailed findings in Section 7.

- Port scanning identified 23 open TCP services, a profile immediately consistent with a well-known intentionally-vulnerable training distribution.
- Three independent, pre-existing backdoors were identified and confirmed without any exploit development required: a trojaned vsftpd build (A-01), a planted root bind shell on port 1524 (A-02), and a trojaned UnrealIRCd build (A-03).
- A Java RMI service was confirmed vulnerable to remote code execution (A-04); exploitation was attempted via Metasploit but the reverse payload callback failed due to the testing workstation's attacking network interface not being routable from the target subnet, an environment/tooling limitation rather than a target-side control.
- Web content discovery identified a DVWA (Damn Vulnerable Web Application) installation alongside phpMyAdmin and TWiki (A-16). Default credentials (admin/password) were used to authenticate to DVWA.
- SQL injection testing against DVWA's 'high' security setting failed against all automated techniques (boolean-blind, error-based, time-based blind, UNION, stacked queries) — confirming that the application's input-escaping at this setting is effective against standard tooling.
- Lowering the application security setting to 'medium' (itself only possible because of the already-compromised admin session) immediately exposed the same parameter to UNION-based injection, since numeric-context input requires no quote characters to break out of the query (A-05).
- The injection was used to enumerate all 7 backend databases and fully dump and crack the application's user-credential table (A-06).
- Database-layer reconnaissance through the same injection point revealed the web application connects to MySQL using the root account with the FILE privilege and no secure_file_priv restriction (A-08) — raising the possibility of escalating SQL injection directly into operating-system command execution.
- An attempt to leverage this into a full OS shell via sqlmap's automated web-shell-drop technique failed: while the database account itself has every required privilege, the underlying web root directory is not writable by the MySQL service's OS-level user account — a working, if perhaps incidental, defense-in-depth control (see Section 9).
- A follow-on attempt at MySQL User-Defined Function (UDF) based privilege escalation was attempted but was a logical non-starter: the database account was already at maximum privilege, leaving nothing to escalate. The corresponding technique for OS command execution via UDF injection (sqlmap's --os-pwn) requires a local Metasploit integration and a correctly routable reverse-connection address, the same environmental constraint that affected the RMI exploitation attempt, and was not completed within the engagement window.
- Credential brute-forcing was attempted against both the phpMyAdmin web login and the native MySQL service for the root account; no valid password was identified within the tested wordlists for either path, including the empty-password case — indicating the database root account does not use the commonly-assumed blank password on this specific build.

7. Detailed Findings — 192.168.15.21

A-01 — vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Severity	Critical
CVSS v3.1 / Reference	10.0 (CVE-2011-2523)
Affected Asset	192.168.15.21 : 21/tcp (FTP)
Status	Exploited — Confirmed

Description:

The FTP service running on the target host was identified as vsftpd version 2.3.4. This specific build was the subject of a well-documented supply-chain compromise in 2011, in which the official source archive distributed from the vsftpd project's hosting infrastructure was replaced with a maliciously modified version. The trojanized binary listens for a backdoor trigger consisting of a smiley-face sequence (":") submitted as part of the FTP username, which causes the service to spawn a command shell bound to TCP port 6200 with no authentication required.

Evidence:

```
$ nmap -sV --script vuln -p 21 192.168.15.21
21/tcp open  ftp  vsftpd 2.3.4
ftp-vsftpd-backdoor:
  VULNERABLE:
    vsftpd version 2.3.4 backdoor
    Shell command successfully executed
    uid=0(root) gid=0(root)
```

Impact:

Successful exploitation grants an unauthenticated remote attacker an interactive command shell running with full root (uid=0) privileges. This represents complete compromise of host confidentiality, integrity, and availability with no authentication, user interaction, or prior access required.

Recommendation:

- Immediately remove or replace the vsftpd 2.3.4 binary with a build obtained from a trusted, verified source (official Debian/Ubuntu package repositories, with checksum verification).
- Treat this host as fully compromised; perform a clean rebuild rather than in-place remediation.
- Implement file-integrity monitoring on production FTP services to detect future binary tampering.
- Restrict FTP service exposure to required network segments only via host- and network-level firewalling.

A-02 — Pre-Installed Unauthenticated Root Bind Shell ("ingreslock")

Severity	Critical
CVSS v3.1 / Reference	N/A — Planted Backdoor (No CVE)
Affected Asset	192.168.15.21 : 1524/tcp
Status	Exploited — Confirmed

Description:

Port 1524/tcp, conventionally registered for the Ingres database lock manager service, was found to be running a raw command shell rather than any legitimate service. Connecting to the port with a standard TCP client immediately returns an interactive root-level shell with no authentication of any kind.

Evidence:

```
$ nc -nv 192.168.15.21 1524
Connection to 192.168.15.21 1524 port [tcp/*] succeeded!
# whoami
root
```

Impact:

This is functionally identical in severity to A-01: complete, unauthenticated, zero-effort root compromise of the host. Any party with network connectivity to this port — including automated internet-wide scanning bots — can obtain a root shell in seconds.

Recommendation:

- Identify and terminate the process bound to port 1524 immediately.
- Audit the host for the presence of other planted listeners using a known-good process and port inventory.
- Rebuild the host from a trusted base image; do not attempt to remediate in place.

A-03 — UnrealIRCd Backdoored Binary

Severity	Critical
CVSS v3.1 / Reference	10.0 (CVE-2010-2075)
Affected Asset	192.168.15.21 : 6667/tcp (IRC)
Status	Confirmed via automated check — exploitation not performed

Description:

The IRC service on port 6667/tcp was identified as UnrealIRCd. Nmap's targeted vulnerability-detection script confirmed the presence of the 2009–2010 supply-chain backdoor in which the official UnrealIRCd source distribution was replaced with a trojanized version containing a hidden remote command-execution trigger.

Evidence:

```
$ nmap -sV --script vuln -p 6667 192.168.15.21
6667/tcp open  irc  Unreal ircd
irc-unrealircd-backdoor:
  Looks like trojaned version of unrealircd. See
  http://seclists.org/fulldisclosure/2010/Jun/277
```

Impact:

Where present, this backdoor permits arbitrary OS command execution as the user account running the IRC daemon, without authentication. Combined with A-01 and A-02, this provides yet another fully independent path to host compromise.

Recommendation:

- Remove the UnrealIRCd installation or replace it with a verified, untampered build.
- Treat as further confirmation that this host's software baseline cannot be trusted; prioritize full rebuild.

A-04 — Java RMI Registry Insecure Default Configuration — Remote Code Execution

Severity	Critical
CVSS v3.1 / Reference	N/A — Design/Configuration Weakness
Affected Asset	192.168.15.21 : 1099/tcp
Status	Confirmed vulnerable — exploitation attempted, result inconclusive

Description:

A Java RMI registry service was identified on port 1099/tcp. By default, the RMI registry and distributed garbage collector permit remote class loading without restriction, which can be abused to instruct the registry to load and execute attacker-supplied Java bytecode, resulting in arbitrary command execution under the privileges of the RMI service process.

Evidence:

```
$ nmap -sV --script rmi-vuln-classloader -p 1099 192.168.15.21
1099/tcp open  java-rmi    Java RMI Registry
rmi-vuln-classloader:
  VULNERABLE:
    RMI registry default configuration remote code execution

msf6 > use exploit/multi/misc/java_rmi_server
msf6 exploit(...) > check
[+] 192.168.15.21:1099 - The target is vulnerable.
```

Impact:

Successful exploitation would grant remote code execution as the user running the RMI service (commonly root on this host class). During this engagement, exploitation was attempted but the reverse payload callback failed due to the attacking workstation having a network interface configuration not routable from the target subnet — an attacker-side environmental limitation, not a property of the target. The vulnerability itself was independently confirmed via two separate detection methods and should be considered live.

Recommendation:

- Disable the RMI registry if not required, or bind it to localhost/internal-only interfaces.
- Apply current JRE/JDK security patches and registry hardening (e.g. enabling a restrictive RMI SecurityManager / serialization filtering) where the service must remain in use.
- Re-test exploitation from an attacking host with verified Layer-3 reachability to the target subnet to obtain a definitive proof-of-exploit.

A-05 — SQL Injection in Custom Web Application (DVWA)

Severity	Critical
CVSS v3.1 / Reference	8.8 (CWE-89, authenticated)
Affected Asset	192.168.15.21 : 80/tcp — /dvwa/vulnerabilities/sqli/
Status	Exploited — Confirmed

Description:

The 'SQL Injection' module of the DVWA web application, accessible to any authenticated application user, fails to safely parameterize the 'id' GET parameter at the application's 'medium' security setting. While the 'high' setting applies output-context escaping that successfully defeated automated quote-based injection testing, the 'medium' and 'low' settings pass the parameter into a numeric query context where injection does not require quote characters at all, allowing UNION-based, boolean-blind, error-based, and time-based blind injection techniques to all succeed.

Evidence:

```
GET /dvwa/vulnerabilities/sqli/?id=1 UNION ALL SELECT NULL,
  CONCAT(...) -- -&Submit=Submit

[INFO] GET parameter 'id' is 'Generic UNION query (NULL) -
  2 columns' injectable
back-end DBMS: MySQL >= 4.1
available databases [7]: dvwa, information_schema, metasploit,
mysql, owasp10, tikiwiki, tikiwiki195
```

Impact:

Full read access to all 7 databases hosted by the backend MySQL instance was obtained, including complete extraction of the application's user-credential table. This represents total compromise of application data confidentiality and, given the elevated database privileges described in finding A-08, materially increases the risk of further lateral compromise.

Recommendation:

- Rewrite all database queries to use parameterized statements / prepared statements rather than string concatenation, for both quoted and numeric input contexts.
- Apply strict server-side input validation (e.g. enforce integer type) on identifier parameters such as 'id' in addition to parameterization, as defense in depth.
- Do not rely on escaping functions such as `mysqli_real_escape_string()` alone — escaping protects only against quote-breakout, not numeric-context injection, as directly demonstrated by this finding.

A-06 — Weak / Default Web Application Credentials

Severity	High
CVSS v3.1 / Reference	8.1 (CWE-521 / CWE-261)
Affected Asset	192.168.15.21 : 80/tcp — /dvwa/login.php
Status	Exploited — Confirmed

Description:

The DVWA application's user-credential table was extracted via the SQL injection finding (A-05). All five stored accounts used MD5-hashed passwords drawn from common dictionaries, and all five were cracked instantly using sqlmap's built-in dictionary attack. Independently, the 'admin' account's default credentials were also found to be valid for direct interactive login prior to any database access, confirming the weakness through two separate methods.

Evidence:

user_id	user	password (cracked)
1	admin	password
2	gordonb	abc123
3	1337	charley
4	pablo	letmein
5	smithy	password

Impact:

Trivially guessable credentials eliminate the practical value of the application's authentication control, allowing any party to gain authenticated access and reach every other vulnerable module behind the login gate.

Recommendation:

- Enforce a strong password policy with minimum complexity and length requirements at account creation.
- Replace MD5 with a modern, salted password hashing algorithm (bcrypt, scrypt, or Argon2).
- Implement account lockout / rate limiting on the login endpoint to slow credential-guessing attacks.

A-07 — Unauthenticated Trust-Based Remote Shell Services (rexec / rlogin / rsh)

Severity	Critical
CVSS v3.1 / Reference	9.8 (CWE-287, design-level)
Affected Asset	192.168.15.21 : 512,513,514/tcp
Status	Identified — not exploited (would require a trusted-host pivot)

Description:

Ports 512, 513, and 514/tcp are running the legacy BSD 'r-services' suite (rexecd, rlogind, rshd). These services authenticate based on source-host/username trust relationships (.rhosts / hosts.equiv) rather than passwords, and transmit all traffic, including any credentials that are used, in cleartext.

Evidence:

512/tcp	open	exec	netkit-rsh rexecd
513/tcp	open	login	OpenBSD or Linux rlogind
514/tcp	open	shell	netkit-rsh rshd

Impact:

Where a trust relationship exists (commonly misconfigured to trust broad network ranges), these services allow remote command execution without any password. Even where authentication is required, credentials are exposed in cleartext to any party able to observe network traffic.

Recommendation:

- Disable the r-services suite entirely; replace with SSH for all remote administration use cases.
- Where decommissioning is not immediately possible, restrict access via firewall to a minimal, explicitly trusted host list.

A-08 — Excessive Database Account Privileges — Web Application Connects to MySQL as root

Severity	High
CVSS v3.1 / Reference	8.6 (CWE-250: Execution with Unnecessary Privileges)
Affected Asset	192.168.15.21 : 3306/tcp
Status	Confirmed

Description:

Queries executed through the SQL injection vulnerability (A-05) were used to determine the database session identity. The DVWA application's database connection authenticates as the MySQL 'root' account, which additionally holds the FILE privilege, and the server's secure_file_priv setting imposes no path restriction on file read/write operations.

Evidence:

```
SELECT CURRENT_USER(): 'root@%'

SELECT user,host,File_priv FROM mysql.user WHERE user='root':

  'root,%,Y'

SELECT @@secure_file_priv,@@datadir,@@version:

',/var/lib/mysql/,5.0.51a-3ubuntu5'
```

Impact:

Any future SQL injection vulnerability discovered in this or any other application sharing this database account inherits full administrative control over the entire MySQL instance, and — were the underlying OS file permissions on the web root less restrictive than was found in this assessment (see Section 11, Positive Security Observations) — could be leveraged directly into operating-system command execution via INTO OUTFILE web-shell upload or UDF injection.

Recommendation:

- Create a dedicated, least-privilege MySQL account for each application, scoped only to the specific schema(s) and statement types (SELECT/INSERT/UPDATE/DELETE) it requires.
- Remove the FILE privilege from any account used by a web application.
- Never use the database root account for application connectivity under any circumstances.

A-09 — Outdated Samba File Sharing Service

Severity	High
CVSS v3.1 / Reference	9.8 (CVE-2007-2447, version-consistent)
Affected Asset	192.168.15.21 : 139,445/tcp
Status	Identified — not exploited

Description:

Samba was identified on ports 139 and 445/tcp at a version consistent with the well-known 'usermap_script' remote command execution vulnerability affecting Samba 3.0.20 through 3.0.25rc3, in which shell metacharacters in a mapped username are passed unsanitized to a system call.

Evidence:

```
139/tcp open  netbios-ssn  Samba smbd 3.X - 4.X
445/tcp open  netbios-ssn  Samba smbd 3.X - 4.X
```

Impact:

If the specific patch level is confirmed vulnerable, unauthenticated remote command execution as root is possible. This was not exploited during this engagement to avoid duplicating proof-of-concept work already established via findings A-01/A-02/A-03, but should be treated as a credible, high-confidence risk given the version match.

Recommendation:

- Upgrade Samba to a current, supported release.
- Disable the 'username map script' configuration option unless explicitly required.

A-10 — Outdated / Historically Compromised ProFTPD Service

Severity	High
CVSS v3.1 / Reference	7.5 (version-consistent with historical backdoor incident)
Affected Asset	192.168.15.21 : 2121/tcp
Status	Identified — not exploited

Description:

A second FTP service, ProFTPD 1.3.1, was identified on port 2121/tcp. This exact version corresponds to a 2010–2011 incident in which the official ProFTPD source distribution mirrors were compromised, in addition to multiple version-specific memory-corruption vulnerabilities.

Evidence:

```
2121/tcp open  ftp  ProFTPD 1.3.1
```

Impact:

Depending on exact build provenance, this service may provide a further independent path to remote command execution or full compromise.

Recommendation:

- Upgrade to a current ProFTPD release obtained from a verified source, or decommission if not required.

A-11 — Outdated VNC Server with Weak Authentication

Severity	High
CVSS v3.1 / Reference	7.5 (CWE-307 / weak authentication scheme)
Affected Asset	192.168.15.21 : 5900/tcp
Status	Identified — not exploited

Description:

A VNC remote desktop server using the very old RFB protocol version 3.3 was identified. Implementations of this protocol generation are known to support only weak, easily-brute-forced password schemes and, in some builds, authentication-bypass flaws.

Evidence:

```
5900/tcp open  vnc    VNC (protocol 3.3)
```

Impact:

Successful authentication (or bypass) grants full interactive graphical desktop control of the host.

Recommendation:

- Upgrade to a current VNC implementation supporting modern authentication, or replace with SSH-tunneled / RDP-with-NLA remote access.
- Enforce a strong, unique VNC password.

A-12 — Unauthenticated Network File System (NFS) Export

Severity	High
CVSS v3.1 / Reference	7.5 (CWE-732: Incorrect Permission Assignment)
Affected Asset	192.168.15.21 : 2049/tcp (plus rpcbind on 111/tcp)
Status	Identified — not exploited

Description:

An NFS service was identified with no host- or authentication-based access restriction confirmed during testing. Combined with the rpcbind service on port 111/tcp, this exposes whatever filesystem paths are configured for export to any host capable of mounting them.

Evidence:

```
111/tcp  open  rpcbind  2 (RPC #100000)
2049/tcp open  nfs       2-4 (RPC #100003)
```

Impact:

Unrestricted NFS exports can expose sensitive files for reading and, where writable, allow planting of malicious files including SUID binaries for local privilege escalation on any host able to mount the share.

Recommendation:

- Run 'showmount -e' against the host to enumerate actual exports and restrict each to an explicit, minimal client list in /etc/exports.
- Disable NFS entirely if not required.

A-13 — Legacy SSL/TLS Weaknesses on Database Service

Severity	Medium
CVSS v3.1 / Reference	5.9 (CVE-2014-3566 / CVE-2014-0224, version-consistent)
Affected Asset	192.168.15.21 : 5432/tcp (PostgreSQL)
Status	Confirmed via automated check

Description:

SSL/TLS negotiation on the PostgreSQL service was found to support the deprecated SSLv3 protocol and a weak Diffie-Hellman key-exchange group, consistent with susceptibility to the POODLE downgrade attack and the OpenSSL 'CCS Injection' man-in-the-middle vulnerability.

Evidence:

```
ssl-poodle: VULNERABLE — SSLv3 padding oracle (POODLE)
ssl-ccs-injection: VULNERABLE — CVE-2014-0224
ssl-dh-params: weak DH group detected
```

Impact:

An on-path attacker may be able to downgrade or decrypt portions of supposedly encrypted database traffic, or perform connection hijacking, undermining confidentiality of data in transit.

Recommendation:

- Disable SSLv3 and weak cipher/DH configurations; permit only TLS 1.2 or higher with strong cipher suites.
- Upgrade PostgreSQL and its underlying OpenSSL library to current, supported versions.

A-14 — Apache Tomcat Manager Interface Exposed

Severity	Medium
CVSS v3.1 / Reference	6.5 (CWE-284, credentialed admin interface exposure)
Affected Asset	192.168.15.21 : 8009/tcp (AJP), 8180/tcp (HTTP)
Status	Identified — not exploited (valid credentials not obtained)

Description:

An Apache Tomcat / Coyote 1.1 instance was identified with its '/manager/html' administrative console reachable (HTTP 401 — authentication required but not bypassed during testing). The AJP connector on 8009/tcp was also found to be directly reachable.

Evidence:

```
8180/tcp open  http  Apache Tomcat/Coyote JSP engine 1.1
/manager/html (401, requires authentication)
8009/tcp open  ajp13  Apache Jserv (Protocol v1.3)
```

Impact:

If default or weak manager credentials are in use, this interface allows direct deployment of a malicious .war file, resulting in remote code execution. A directly exposed AJP connector is also a known vector for file-disclosure/RCE attacks (e.g. 'Ghostcat') on vulnerable Tomcat versions.

Recommendation:

- Restrict access to the Manager application to localhost or an administrative VPN/jump-host only.
- Set a strong, unique Manager password or disable the Manager app if unused.
- Bind the AJP connector to localhost or disable it if not required by a fronting web server.

A-15 — WebDAV Enabled on Production Web Server

Severity	Medium
CVSS v3.1 / Reference	5.3 (CWE-650)
Affected Asset	192.168.15.21 : 80/tcp
Status	Identified

Description:

The Apache HTTP Server banner advertises 'DAV/2', and a '/dav/' directory was discovered during content enumeration, indicating WebDAV is enabled on the production web server.

Evidence:

```
Server: Apache/2.2.8 (Ubuntu) DAV/2
/dav/ (301)
```

Impact:

Misconfigured WebDAV deployments have historically allowed unauthenticated file upload via PUT requests, which can be leveraged to upload a web shell and achieve remote code execution.

Recommendation:

- Disable the WebDAV module unless explicitly required.
- If required, restrict PUT/MOVE/DELETE methods to authenticated, authorized users only via web server configuration.

A-16 — Additional Vulnerable Web Applications Exposed (phpMyAdmin, TWiki)

Severity	Medium
CVSS v3.1 / Reference	N/A — Attack Surface / Exposure Finding
Affected Asset	192.168.15.21 : 80/tcp — /phpMyAdmin/, /twiki/
Status	Identified — not exploited

Description:

Content discovery against the web root identified additional installed applications beyond DVWA, including a phpMyAdmin database-administration console and a TWiki wiki installation. TWiki versions of this era carry a well-documented unauthenticated command-injection vulnerability.

Evidence:

```
/phpMyAdmin/  (301)
/twiki/       (301)
```

Impact:

Each additional exposed application represents independent attack surface. TWiki in particular is associated with a known, reliable remote command execution exploit; phpMyAdmin exposure increases risk if weak or default database credentials exist anywhere on the host.

Recommendation:

- Remove or restrict access to administrative and demonstration applications not required for production use.
- Where retained for training purposes, isolate on a network segment with no inbound access from untrusted networks.

A-17 — Full Path Disclosure via SQL Injection

Severity	Low
CVSS v3.1 / Reference	5.3 (CWE-200: Information Exposure)
Affected Asset	192.168.15.21 : 80/tcp
Status	Confirmed

Description:

During exploitation of finding A-05, automated path-disclosure probing returned the absolute filesystem path of an application include file, along with the web server document root.

Evidence:

```
retrieved the web server document root: '/var/www'
retrieved web server absolute paths:
'/var/www/dvwa/dvwa/includes/dvwaPage.inc.php'
```

Impact:

Disclosed server-side paths assist an attacker in crafting subsequent, more targeted file-inclusion or file-write attacks and reduce the effort required for further exploitation.

Recommendation:

- Disable verbose PHP error reporting in production (display_errors = Off).
- Apply a custom error-handling page that does not reflect internal application state.

A-18 — Cleartext Telnet Service

Severity	Low
CVSS v3.1 / Reference	5.9 (CWE-319: Cleartext Transmission)
Affected Asset	192.168.15.21 : 23/tcp
Status	Identified

Description:

A Telnet service was identified, which transmits all session data, including authentication credentials, without encryption.

Evidence:

```
23/tcp open  telnet  Linux telnetd
```

Impact:

Any party able to observe network traffic between a client and this service can recover login credentials and full session content.

Recommendation:

- Disable Telnet and migrate all remote administrative access to SSH.

A-19 — Outdated SSH Daemon Version

Severity	Low
CVSS v3.1 / Reference	N/A — version-dependent; automated CVE matching unreliable for this build
Affected Asset	192.168.15.21 : 22/tcp
Status	Identified

Description:

OpenSSH 4.7p1 was identified, a release from 2007. Automated vulnerability-correlation tooling (the 'vulners' NSE script) returned a long list of associated CVEs spanning multiple years; manual review found many of these to be false positives caused by loose product/version-string matching rather than genuine applicability, including several CVEs dated years after this software's release. The findings below are limited to what is reasonably attributable to this specific, very old build.

Evidence:

```
22/tcp open  ssh  OpenSSH 4.7p1 Debian 8ubuntu1
```

Impact:

Running software nearly two decades past its release misses many years of accumulated security hardening and patches, independent of any single named CVE.

Recommendation:

- Upgrade OpenSSH to a current, vendor-supported release.
- When using automated CVE-correlation tools generally, manually validate matches against the exact vendor/version before reporting them as confirmed findings.

A-20 — Outdated DNS Server (BIND)

Severity	Low
CVSS v3.1 / Reference	N/A — version-dependent, not independently exploited
Affected Asset	192.168.15.21 : 53/tcp
Status	Identified

Description:

ISC BIND 9.4.2 was identified, a release with multiple subsequently disclosed denial-of-service and cache-poisoning class vulnerabilities.

Evidence:

```
53/tcp open  domain  ISC BIND 9.4.2
```

Impact:

Depending on exact patch level, may be susceptible to denial-of-service or cache-poisoning attacks affecting DNS resolution integrity/availability.

Recommendation:

- Upgrade to a current, supported BIND release or alternative DNS server software.

8. Detailed Findings — 192.168.9.69

Testing against this host was limited to reconnaissance-depth port scanning and service identification; no exploitation was attempted or required to support the findings below.

B-01 — Unidentified Service on Port 514/tcp

Severity	Informational
CVSS v3.1 / Reference	N/A
Affected Asset	192.168.9.69 : 514/tcp
Status	Identified — requires manual verification

Description:

A port-scan service-detection heuristic tentatively flagged port 514/tcp as a possible shell-type service, but could not confirm this with sufficient confidence (reported with a '?' confidence marker). This is a different host and finding from the confirmed r-services on the Metasploitable2 host (A-07) and should not be conflated with it.

Evidence:

```
514/tcp open  shell?
```

Impact:

Unknown pending manual verification; the service could be benign (e.g. a syslog listener, which conventionally also uses 514 over UDP) or could represent unexpected/unauthorized software.

Recommendation:

- Manually connect to and identify the service (e.g. via banner-grab or process inspection on the host) and confirm it is authorized and intentionally exposed.

B-02 — Third-Party Helpdesk Web Component Exposed

Severity	Informational
CVSS v3.1 / Reference	N/A
Affected Asset	192.168.9.69 : 8081/tcp
Status	Identified

Description:

A web application was identified on port 8081/tcp returning Content-Security-Policy headers referencing 'desk.zoho.com' and 'static.zohocdn.com', indicating an installed component related to the Zoho Desk helpdesk platform (e.g. a self-hosted agent or integration component) rather than a generic web server.

Evidence:

```
8081/tcp open  http
Content-Security-Policy: ...desk.zoho.com static.zohocdn.com...
```

Impact:

Unexpected or unmanaged third-party software increases the host's attack surface and should be accounted for in the organization's asset inventory and patch-management process.

Recommendation:

- Confirm this component is authorized, currently supported by its vendor, and kept up to date.
- Restrict network exposure of this interface to only the users/systems that require it.

9. Positive Security Observations

Not every result of this engagement was negative. The following controls were observed working as intended and are noted to ensure they are preserved during any remediation effort:

- 192.168.9.69 enforces SMB signing (required, not merely enabled) on its file-sharing service, which mitigates SMB relay attacks — a control frequently found missing in real-world environments.
- DVWA's 'high' application security setting, which applies proper escaping to user input, successfully defeated every automated SQL injection technique attempted against it, directly demonstrating that input sanitization is an effective control against this vulnerability class when correctly implemented.
- Operating-system-level directory permissions on the web root (owned by a non-database service account) prevented a fully-privileged, root-equivalent MySQL account from writing a web shell to disk, blocking one complete attack chain from SQL injection to remote code execution. This illustrates the value of defense-in-depth: an excessive database privilege (A-08) was rendered non-exploitable, in this instance, by an unrelated, correctly-configured OS-level control.
- No valid credentials were recovered for the MySQL or phpMyAdmin 'root' account against the wordlists tested, including the commonly-assumed blank password, indicating this particular account's authentication has not been left at a trivially-guessable default.

10. Testing Limitations

- Time-boxed nature of the engagement: not every identified service (e.g. Samba, ProFTPD, NFS) was taken through to full proof-of-concept exploitation; several High-severity findings (A-07, A-09, A-10, A-11, A-12) were validated to the point of high-confidence identification but not independently exploited, primarily to avoid duplicating proof-of-compromise already established via findings A-01–A-03.
- Network routing constraints on the testing workstation prevented completion of two planned exploits requiring an outbound reverse-connection callback (the Java RMI exploit, finding A-04, and the SQLi-to-OS-shell escalation attempt described in the Attack Narrative). Both vulnerabilities were nonetheless independently confirmed present via non-exploitation-dependent verification methods, and re-testing from a properly network-positioned host is recommended to obtain definitive proof-of-exploit artifacts.
- Automated vulnerability-correlation tooling (the Nmap ‘vulners’ NSE script) was found during this engagement to produce a meaningful rate of false positives, including CVE references post-dating the software versions being matched. All such results were manually reviewed before inclusion in this report; any client-side use of similar tooling should incorporate the same manual validation step.
- An initial credential-testing attempt against the phpMyAdmin login form returned uniformly “successful” results across all tested passwords; this was identified during testing as a false-positive condition caused by an incorrectly configured failure-detection string, corrected before any results were relied upon. This is noted for completeness and as a reminder that brute-force tooling output requires success/failure criteria to be validated against the target's actual behavior before being trusted.

11. Recommendations & Remediation Roadmap

Remediation actions are grouped below by priority. Individual finding IDs are referenced for traceability back to Section 7/8 detail.

11.1 Immediate (within 24–48 hours)

- Treat 192.168.15.21 as fully compromised. Isolate from any network with production or sensitive-data access and rebuild from a trusted, current base image rather than attempting in-place remediation. [A-01, A-02, A-03]
- Remove or restrict the r-services suite (rexec/rlogin/rsh). [A-07]
- Rotate all credentials discovered or used during this engagement, including the DVWA application accounts. [A-06]

11.2 Short-Term (within 2 weeks)

- Re-architect database connectivity so the web application uses a dedicated, least-privilege MySQL account rather than root, with the FILE privilege removed. [A-08]
- Patch or upgrade Samba, ProFTPD, VNC, and BIND to current supported versions. [A-09, A-10, A-11, A-20]
- Restrict or disable NFS exports; if required, scope to an explicit, minimal client allow-list. [A-12]
- Re-test the Java RMI (A-04) and SQLi-to-OS-shell escalation paths from a properly network-positioned attacking host to obtain definitive exploitation confirmation, and remediate the underlying RMI default-configuration weakness regardless of re-test outcome.

11.3 Medium-Term (within 90 days)

- Rewrite the web application's database access layer to use parameterized queries throughout, with server-side type validation on all identifier-style parameters. [A-05]
- Disable WebDAV, restrict the Tomcat Manager interface, and remove or isolate the additional exposed web applications (phpMyAdmin, TWiki) not required for production. [A-14, A-15, A-16]
- Disable Telnet in favor of SSH, and upgrade SSH/PostgreSQL/Tomcat to current versions with modern TLS configuration. [A-13, A-18, A-19]
- Disable verbose application error output to prevent path-disclosure information leakage. [A-17]
- Confirm and document the purpose of all unverified/unexpected services identified on 192.168.9.69. [B-01, B-02]

12. Conclusion

This engagement successfully demonstrated complete compromise of 192.168.15.21 through multiple independent attack paths, ranging from pre-existing, zero-effort backdoors to a fully-chained SQL injection exploitation leading to credential theft. The host's overall posture is consistent with an intentionally vulnerable training/lab system and is not suitable for any role beyond isolated security education. 192.168.9.69, assessed at a lighter depth, presented a comparatively stronger baseline posture with no critical findings identified within the tested scope. Organizations operating real production systems with any of the weakness patterns identified in this report — supply-chain-compromised software, excessive database privileges, weak default credentials, or unpatched decade-plus-old services — face equivalent risk and should prioritize remediation accordingly.

This is a sample report based on the Metasploitable2

Appendix A: Tools Used

Tool	Purpose
Nmap	Network port scanning, service/version detection, NSE vulnerability scripts
Gobuster	Web content/directory discovery
Nikto	Web server vulnerability scanning (attempted; limited by tooling infrastructure constraints)
sqlmap	SQL injection detection, exploitation, database enumeration/dumping, privilege analysis
Hydra	Online credential brute-forcing (HTTP form and native MySQL protocol)
Metasploit Framework (msfconsole)	Exploit verification and attempted exploitation (Java RMI)
netcat / curl	Manual protocol-level verification and backdoor confirmation

This is a sample report based on the Metasploit Framework

Appendix B: Full Port / Service Inventory — 192.168.15.21

Port	Service	Version / Notes
21/tcp	FTP	vsftpd 2.3.4 (backdoored)
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
53/tcp	DNS	ISC BIND 9.4.2
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
111/tcp	RPC	rpcbind 2 (RPC #100000)
139/tcp	NetBIOS-SSN	Samba smbd 3.X-4.X
445/tcp	NetBIOS-SSN	Samba smbd 3.X-4.X
512/tcp	exec	netkit-rsh rexecd
513/tcp	login	rlogind
514/tcp	shell	netkit-rsh rshd
1099/tcp	Java RMI	Java RMI Registry
1524/tcp	bindshell	Metasploitable root shell (planted backdoor)
2049/tcp	NFS	2-4 (RPC #100003)
2121/tcp	FTP	ProFTPD 1.3.1
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5
5432/tcp	PostgreSQL	PostgreSQL 8.3.0-8.3.7
5900/tcp	VNC	VNC (protocol 3.3)
6000/tcp	X11	(access denied to remote connections)
6667/tcp	IRC	UnrealIRCd (backdoored)
8009/tcp	AJP	Apache Jserv Protocol v1.3
8180/tcp	HTTP	Apache Tomcat/Coyote JSP engine 1.1

Appendix C: Full Port / Service Inventory — 192.168.9.69

Port	Service	Version / Notes
135/tcp	MSRPC	Microsoft Windows RPC
139/tcp	NetBIOS-SSN	Microsoft Windows NetBIOS
445/tcp	microsoft-ds	SMB (signing enabled and required, SMBv3.1.1)
514/tcp	shell?	Unconfirmed (see finding B-01)
8081/tcp	HTTP	Zoho Desk-related web component (see finding B-02)

This is a sample report based on the Metasploitab